

Vulnerability Assessment Report

Target Website: www.svce.ac.in

Prepared by: VENKATA BHARGAV CH S

Date: June 2026

Finding 1: Information Disclosure **(Exposed Server Version)**

Risk Level: Medium

- **What is the issue?** During the passive scan, it was discovered that the website is publicly broadcasting the exact version of its web server software (Apache 2.4.18).
- **Why does it matter?** Exposing the exact software version gives attackers a massive advantage. Instead of guessing how to hack the website, they can look up known weaknesses for this specific old version of Apache and launch a targeted attack.
- **Remediation Steps (How to fix it):** The IT team should hide this version number. They can do this by opening the Apache configuration file and changing the settings to: **ServerTokens**
ProdServerSignature Off

Finding 2: Missing HTTP Security Headers

Risk Level: Medium 🟡

- **What is the issue?** The website is missing important security instructions (called HTTP Security Headers) in its background code. Specifically, critical headers like X-Frame-Options and Content-Security-Policy are completely absent.
- **Why does it matter?** Without these headers, the website lacks a basic layer of defense. For example, lacking X-Frame-Options leaves the site vulnerable to "Clickjacking." This means an attacker could invisibly load this website inside their own malicious site, tricking visitors into clicking links or giving away passwords without realizing it.
- **Remediation Steps (How to fix it):** The web developer should update the server configuration to automatically enforce strict security headers on all web pages. At a minimum, they need to add X-Frame-Options: SAMEORIGIN to block malicious framing.

Finding 3: Absence of Anti-CSRF Tokens

Risk Level: Medium 

- **What is the issue?** An OWASP ZAP passive scan detected that HTML forms on the website do not include Anti-CSRF (Cross-Site Request Forgery) tokens.
- **Why does it matter?** Without these secure tokens, an attacker can trick a user's browser into silently submitting unwanted actions on the website without the user's knowledge or consent.
- **Remediation Steps (How to fix it):** The development team should implement a "Synchronizer Token Pattern." This means generating a unique, unpredictable, and hidden token for every HTML form that the server verifies before accepting any submitted data.

Evidence 1: Nmap Port Scan Output

- 80/tcp open http Apache httpd 2.4.18 ((Ubuntu))
- 443/tcp open ssl/http Apache httpd 2.4.18 ((Ubuntu))

```
(kali@kali)-[~]
$ sudo nmap -sV -F svce.ac.in
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-17 12:51 +0530
Nmap scan report for svce.ac.in (111.93.240.11)
Host is up (0.0096s latency).
Not shown: 97 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
53/tcp    open  domain  ISC BIND 9.10.3-P4 (Ubuntu Linux)
80/tcp    open  http    Apache httpd 2.4.18 ((Ubuntu))
443/tcp   open  ssl/http Apache httpd 2.4.18 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.11 seconds
```

Evidence 2: Browser DevTools (Network Headers)

The screenshot displays the SVCE (Sri Venkateswara College of Engineering) website. The header includes navigation links: Home, About, Academics, Fees, Admissions, Merit Based Management Admissions, News, and Contact. The main content area features several notices, including a relocation notice for the Kotturpuram Office and an admissions notice for 2026. The Network DevTools panel is open, showing a list of requests. The table below represents the data from the Network panel.

Name	Status	Type	Initiator	Size	Time
css?family=Roboto_old	200	stylesheet	messenger-internal.min.js	(memory ca...)	0 ms
dfMessenger-36849133	200	preflight	Preflight	0.0 kB	438 ms
KFOmCnqEu92Fr1Mu4mxK.woff2	200	font	css?family=Roboto_old	(memory ca...)	0 ms
styles_ltr.css	200	stylesheet	anchor?ar=1&k=6ldT8rA	(disk cache)	3 ms
recaptcha_en_gb.js	200	script	anchor?ar=1&k=6ldT8rA	(disk cache)	9 ms
dfMessenger-36849133	429	xhr	messenger-internal.min.js	0.2 kB	326 ms
webworker.js?hl=en-GB&v=MerVUTRoajKE...	200	script	Other	0.0 kB	196 ms
logo_48.png	200	png	styles_ltr.css	(disk cache)	6 ms
KFO7CnqEu92Fr1ME7kSn66aGLdTylUAMa3yU...	200	font	anchor?ar=1&k=6ldT8rA	(disk cache)	5 ms
recaptcha_en_gb.js	200	text/javascript	webworker.js?hl=en-GB&	(disk cache)	7 ms
favicons.png	200	png	Other	(disk cache)	1 ms
svce-1.ico	200	vnd.microso...	Other	(disk cache)	3 ms
reload?k=6ldT8rAUAaaaaAAcY2c5LPfiwtzInL...	200	xhr	recaptcha_en_gb.js:1141	2.3 kB	139 ms
cl?k=6ldT8rAUAaaaaAAcY2c5LPfiwtzInLID-x2...	200	fetch	recaptcha_en_gb.js:1597	0.0 kB	129 ms
why-svce-mobile.png	404	text/html	Other	32.8 kB	434 ms
clickwoff	200	font	click-theme.css	1.7 kB	50 ms

Summary: 226 requests, 205 kB transferred, 23.8 MB resources, Finish: 1 min, DOMContentLoaded: 1.15 s, Load: 1.93 s

Evidence 3: OWASP ZAP Passive Scan Alerts

